

**VIETNAM NATIONAL UNIVERSITY, HO CHI MINH CITY
UNIVERSITY OF INFORMATION TECHNOLOGY**

**DEVELOPMENT OF AI-ENHANCED
SECURITY ALERT ANALYSIS AUTOMATION
SYSTEM FOR SOC**

GRADUATION THESIS SUMMARY

Student: Nguyễn Thái Hoàng

ID: 24410168

Major: Information Technology

Supervisor: M.Sc. Tô Nguyễn Nhật Quang

HO CHI MINH CITY, 2026

Abstract

In the context of increasing cyber-attack complexity, modern Security Operations Centers (SOC) face significant challenges related to "Alert Fatigue." Manual analysis of security events causes delays in Mean Time to Respond (MTTR) and increases the risk of human error. This thesis presents the development of an automated security alert analysis system that integrates SIEM (Splunk), SOAR (n8n), and Artificial Intelligence (OpenAI GPT-4o-mini). The system automates log collection, context enrichment via Threat Intelligence (AbuseIPDB), and utilizes Large Language Models (LLMs) to perform tasks traditionally handled by Tier 1 SOC analysts. Experimental results on 373 security events demonstrate that the system reduces MTTR from ~20 minutes to 10-15 seconds (~80x improvement) with a classification accuracy of 96.2%.

1. Introduction

1.1. Context and Problem Statement

According to the SANS 2025 SOC Survey, 79% of global SOCs operate 24/7. However, 42% of organizations merely "dump data" into storage without effective exploitation plans. The primary hurdle for analysts is alert fatigue—thousands of events per second lead to burnout and missed genuine threats. Manual processes prolong the MTTR, which globally averages 241 days to identify and contain a breach.

1.2. Project Objectives

- **Monitoring Infrastructure:** Deploy Splunk SIEM for centralized log management.
- **Workflow Automation:** Design SOAR playbooks on n8n to replace manual intake.
- **Intelligent Enrichment:** Integrate AbuseIPDB API for automated entity reputation scoring.
- **AI Analysis:** Apply OpenAI GPT-4o-mini to analyze context, map attacks to the MITRE ATT&CK matrix, and provide remediation.
- **Performance Optimization:** Achieve MTTR < 15 seconds and classification accuracy > 90%.

2. System Architecture and Technologies

The system follows a tiered architecture, ensuring a clear separation between collection, orchestration, and analysis layers.

2.1. Component Stack

Tier	Technology	Role
Endpoint	Windows 10 / Splunk UF	Log generation and forwarding (Event IDs 4625, 4104, 5156).
Detection (SIEM)	Splunk Enterprise	Central indexing, SPL-based rule detection, and Webhook alerting.
Orchestration (SOAR)	n8n (Self-hosted)	Workflow management, data normalization, and API coordination.
Intelligence & AI	AbuseIPDB / OpenAI	IP reputation scoring and advanced incident reasoning.
Interaction	Slack	Multi-channel delivery of structured security reports.

2.2. Logic Data Flow

- Ingestion:** Splunk Universal Forwarder (UF) sends telemetry from the victim endpoint to the Splunk Server via port 9997.
- Detection:** Scheduled SPL searches monitor logs. If a threshold is crossed (e.g., >15 failed logins in 5 mins), a Webhook alert is triggered.
- Normalization:** n8n receives the JSON payload. A Function Node (JavaScript) maps inconsistent fields (e.g., SRC_IP vs Source_Address) into a unified object.
- Enrichment:** For IP-related alerts, n8n queries AbuseIPDB for a confidence score and ISP details.
- AI Processing:** The enriched context is sent to OpenAI with a specific "SOC Analyst" persona prompt.
- Response:** Structured Markdown reports are routed to specific Slack channels (e.g., #alert-malware, #alert-ddos).

3. Detailed Implementation and Methodology

3.1. Monitoring Configuration

Crucial log sources were enabled on the Windows 10 victim machine using `inputs.conf` and Sysmon. Key monitored events include:

- **Security Log (4625):** Failed logons for Brute Force detection.
- **PowerShell Log (4104):** Script block logging to detect malicious commands and reverse shells.
- **Firewall Log (5156):** Network connections to detect DDoS and Tor-based activity.

3.2. Automation Workflow on n8n

The SOAR layer utilizes a complex n8n workflow designed for reliability and scalability. A core innovation is the **Dynamic Routing Logic**. Based on the `search_name` from Splunk, the system automatically assigns a destination Slack channel. This prevents information overload and ensures the right specialized team sees relevant alerts.

3.3. AI Persona and Prompt Engineering

The system employs a multi-layer Prompt Engineering strategy to ensure consistent and high-quality analysis:

- **Task Layer:** Directs the AI to summarize, enrich, assess, and recommend.
- **Constraint Layer:** Enforces a strict Markdown format for Slack readability.
- **Logic Layer:** Instructs the AI to cross-check data (e.g., verifying if "Brute Force" labels align with the attempt count).

The **System Prompt** defines the AI's role as a "Tier 1 SOC Analyst Assistant," while the **User Prompt** provides dynamic data input using Liquid logic to filter out "N/A" fields and reduce noise.

4. AI-Powered Analysis Logic

4.1. Severity Scoring Model

Severity is not static. It is calculated using a weighted model:

$$Final_Severity = MAX(Base_Severity, Threat_Intel_Modifier)$$

- **Upgrade:** If Abuse Confidence Score > 80% or IP is a Tor Exit Node, the severity is bumped (e.g., High to Critical).
- **Downgrade:** If the behavior is labeled as BENIGN in the dataset or matches a whitelist, it is set to Informational.

4.2. Automated MITRE ATT&CK Mapping

The system translates raw logs into Indicators of Behavior (IoB) by mapping detected events to MITRE techniques:

Scenario	Tactic	Technique (ID)	Trigger Logic
Brute Force	Credential Access	T1110	EventCode 4625 or 5156 targeting port 3389.
Malware	Execution	T1059.001	PowerShell scripts containing WebClient/iex.
Evasion	Defense Evasion	T1036.002	Detection of RTLO Unicode characters.
DDoS	Impact	T1498.001	Connection count > 500 packets/10s.

4.3. Remediation Recommendations

Tailored advice is provided based on the mapped MITRE technique: - **For T1110:** Reset compromised accounts, implement MFA, and block the source IP via firewall. - **For T1059.001:** Isolate the host, terminate suspicious processes, and remove registry persistence keys.

5. Attack Simulation Scenarios

Four distinct scenarios were implemented to validate the system's cross-functional capabilities.

5.1. Anonymous Brute Force (Tor + Ngrok)

To simulate advanced persistent threats (APT), the attacker used a proxy-chaining script that rotated Tor Exit Nodes every few attempts. This bypasses traditional IP-based threshold blocking. - **Challenge:** Windows sees the connection as `::1` (localhost) due to Ngrok tunneling. - **Result:** Splunk correctly identified the high velocity of Event 4625, and the AI warned that localhost IPs in this context indicate tunneling tools.

5.2. Evasive Malware Execution

Malicious payloads were generated using the **Villain Framework** and disguised using: - **RTLO (Right-to-Left Override):** Changing `document.fdp.exe` to display as `document.exe.pdf`. - **Homoglyph Attack:** Using non-Latin characters visually identical to Latin ones. - **Result:** AI analysis of the PowerShell script blocks (Event 4104) successfully flagged the "Hidden Window" and "Reverse Shell" patterns despite the visual deception.

5.3. DDoS SYN Flood

Simulated using `hping3`, firing 68 alerts in a 15-second window (~4.5 alerts/sec). - **Challenge:** Testing the SOAR layer's stability under "log blast" conditions. - **Result:** n8n handled the concurrent Webhooks without latency accumulation, proving production-readiness.

5.4. Dataset Validation (CIC-IDS-2017)

A Python script (`ingest_samples.py`) replayed 200 samples from the international standard dataset. This provided a "ground truth" to measure accuracy objectively.

6. Performance Evaluation and Results

6.1. Mean Time To Respond (MTTR) Comparison

MTTR was measured from the moment Splunk indexed the event to the appearance of the analysis on Slack.

Process Stage	Manual Process (Est.)	Automated System	Improvement
Detection	3-5 Minutes	1-2 Seconds	~150x Faster
Enrichment	2-3 Minutes	2 Seconds	~75x Faster
Analysis	5-10 Minutes	8-10 Seconds	~75x Faster
Reporting	2-5 Minutes	1 Second	~120x Faster
Total MTTR	~12-22 Minutes	~10-15 Seconds	~80x Faster

6.2. Accuracy and Classification

On a total of 373 test events, the system achieved the following:

- **Classification Accuracy:** 96.2%
- **MITRE Mapping Accuracy:** 100% for Live attacks, >90% for Dataset.
- **False Negatives:** Only 1 instance (due to a Webhook congestion during a stress test).

6.3. System Utilization Analysis (M/G/1 Model)

The thesis applies the **M/G/1 Queueing Theory** to predict system bottlenecks, specifically at the AI inference stage. The average wait time W is determined by:

$$W = (\lambda E[S^2]) / (2(1 - \rho))$$

Where λ is the arrival rate and S is the AI processing time. When $\rho = \lambda \times E[S] \geq 1$, the system enters a saturated state. This model was used to justify a 1-second delay (throttling) in the ingestion script to maintain system stability.

7. Discussion and Limitations

7.1. Technical Challenges

- **API Rate Limits:** Cloud AI services (OpenAI) have strict rate limits that can hinder responses during massive DDoS attacks.
- **Data Privacy:** Sending logs to the cloud poses a potential risk. Following **NIST 800-144**, sensitive PII should be redacted before transmission.

7.2. Comparison: Cloud AI vs. Local AI

While Local LLMs (e.g., Llama 3) offer superior data privacy, they require significant hardware (GPU) resources. For this project, Cloud AI was chosen for its superior reasoning capabilities and lower infrastructure overhead on the lab environment (i5-12500H).

8. Conclusion and Future Work

This project successfully demonstrated the feasibility of an AI-integrated SOC automation system. By combining Splunk's detection power, n8n's orchestration, and OpenAI's analytical depth, the system effectively eliminated the "Tier 1 bottleneck."

8.1. Future Roadmap

- **Active Response:** Transition from "Notification" to "Active Action" (e.g., automatically executing `netsh` commands to block IPs).
- **Local AI Integration:** Deploying Ollama/Llama 3 locally once dedicated GPU hardware is available to ensure 100% data sovereignty.
- **Broader Intelligence:** Incorporating VirusTotal and Shodan APIs for deeper malware and infrastructure analysis.

References

[1] SANS SOC Survey 2025. [2] Palo Alto Networks, Cortex XSOAR Datasheet. [3] IBM Cost of a Data Breach Report 2025. [4] MITRE ATT&CK Framework. [5] NIST SP 800-144.